

Versión 1.0.6 — Medidas de seguridad

Borrador en curso. Une la base de seguridad del entorno de desarrollo (documento 5: agente de IA, Dev Container, hooks de Git, reglas del servidor) con las medidas del sitio público. Es la puerta previa al alta en Supabase y a las reglas de IAM.

VERSIÓN 1.0.6 · borrador	FECHA 2026-10-05 (inicio)	BASE Documento 5 · v5-dev-security.html	PUERTA PARA Proyecto Supabase + IAM
------------------------------------	-------------------------------------	---	---

Nada de esta versión está implementado todavía. Este documento recoge el estado comprobado y el plan. Cada medida pasa a «hecha» solo cuando su prueba de la matriz (§6) está registrada en el pull request correspondiente.

1 Resumen y alcance

1.0.5 consolidó todo lo anterior y dejó libre la versión 1.0.6, que el documento 5 ya reservaba para la base de seguridad (su nota del §9 sobre el número de versión queda resuelta). 1.0.6 tiene dos partes:

PARTE A · DESARROLLO Agente de IA aislado en un Dev Container, hooks de Git que no se pueden saltar en silencio y reglas en GitHub que sí bloquean. Especificado en el documento 5; aquí se resume (§3).	PARTE B · SITIO PÚBLICO DNS y proxy de Cloudflare, HTTPS estricto, cabeceras de seguridad, CSP, integridad de scripts, formularios, pedidos por WhatsApp, terceros y datos en el navegador (§4).	PUERTA · SUPABASE Solo con A y B en marcha se crea el proyecto Supabase, se sustituyen las cuentas de staging y se aplican las reglas de credenciales e IAM (documento 5, §8).
--	--	--

2 Estado actual comprobado (2026-10-05)

Comprobado sobre producción ([lameyer.net](#)) y sobre el repositorio en [59a81ca](#) . El readme decía que el sitio pasaba por el proxy de Cloudflare; no es así.

Punto	Evidencia	Riesgo
DNS y proxy	NS dns1/dns2.registrar-servers.com (Namecheap); A → 185.199.108-111.153 (GitHub Pages); respuesta <code>server: GitHub.com</code> , sin <code>cf-ray</code>	ALTA Ninguna capa de la serie «Seguridad de APIs» del blog protege hoy el propio sitio: sin WAF, sin rate limiting, sin cabeceras propias.
DNSSEC · CAA	Sin registro DS; sin CAA	MEDIA Respuestas DNS falsificables; cualquier CA puede emitir para el dominio.
HTTPS	http:// → 301 a https:// (GitHub Pages «Enforce HTTPS»); sin <code>Strict-Transport-Security</code>	MEDIA La primera visita por HTTP se puede interceptar (SSL stripping).
Cabeceras	Solo <code>cache-control: max-age=600</code> . Sin CSP, <code>X-Content-Type-Options</code> , <code>Referrer-Policy</code> , <code>Permissions-Policy</code> ni protección contra iframes	ALTA Clickjacking sobre el login y el carrito; ningún freno a scripts inyectados.
Scripts de terceros	React, React DOM y Babel desde cdnjs sin <code>integrity</code> en ninguna página; Tailwind Play CDN; Babel compila el JSX en el navegador	ALTA Un CDN comprometido ejecuta código en todas las páginas. Babel en el navegador obliga a permitir scripts en línea en la CSP.
XSS en el código	Sin <code>innerHTML</code> , <code>dangerouslySetInnerHTML</code> , <code>eval</code> ni <code>new Function</code> propios; React escapa el contenido; JSON-LD con <code>textContent</code>	BAJA Bien. Mantenerlo con la regla de CI del §4.3.
Enlaces externos	Todos los <code>target="_blank"</code> llevan <code>rel="noopener noreferrer"</code>	BAJA Bien.

Cuentas de staging	<code>lm-users</code> guarda hashes SHA-256 con sal en <code>localStorage</code> ; sesión en <code>lm-session</code>	MEDIA Aceptable en staging; no debe llegar a producción como «cuentas reales».
Formulario de contacto	POST <code>no-cors</code> a Google Apps Script; solo un campo trampa (honeypot); URL del script pública en <code>js/layout.jsx</code>	MEDIA Spam y relleno de la hoja; no hay límite de envíos.
Pedidos por WhatsApp	El mensaje (productos, precios, total) se construye en el navegador	MEDIA Un cliente puede editar precios en el mensaje. El paso 2 de los términos (confirmación por Lameyer) es el control.
Terceros con datos	GeoJS (IP, al cargar si no hay bandera), Google Fonts (IP), Frankfurter, Simple Icons, Unsplash, <code>raw.githubusercontent.com</code> (logo), Google Apps Script, WhatsApp	MEDIA La IP llega a terceros antes del consentimiento de cookies (GeoJS, Google Fonts).
Repositorio	Del documento 5 §1: commits desde la web de GitHub, copia de trabajo en OneDrive, sin <code>.gitignore</code> , sin hooks ni CI, sin reglas en <code>main</code> ; <code>.claude/</code> sin seguimiento	ALTA En cuanto existan secretos, nada impide subirlos.

3 Parte A · Entorno de desarrollo (documento 5)

Se adopta el documento 5 sin cambios de diseño. El código completo (`devcontainer.json`, `Dockerfile`, `managed-settings.json`, `agent-guard.sh`, hooks, `gitleaks.toml`, `guard.yml`) está en sus §3–5.

Capa	Medida	Doc. 5
1 · Agente	Claude Code solo dentro del contenedor; ajustes gestionados de root (deny + guardia <code>PreToolUse</code>) que el agente no puede editar; sin credenciales de GitHub ni Supabase; cortafuegos de salida con lista blanca.	§3.1–3.5
2 · Estación	Hooks <code>pre-commit</code> , <code>commit-msg</code> , <code>pre-push</code> de root en <code>/opt/lameyer/hooks</code> ; gitleaks con reglas de Supabase; el agente solo hace commits en ramas <code>ai/*</code> y nunca hace push.	§4
3 · Servidor	Ruleset de <code>main</code> sin lista de excepciones, CI <code>guard</code> obligatorio, secret scanning con push protection, etiqueta <code>security-reviewed</code> para cambios en <code>.github/</code> , <code>.githubhooks/</code> , <code>.devcontainer/</code> .	§5

Ajuste para 1.0.6. La lista blanca del cortafuegos (doc. 5 §3.5) debe añadir los hosts nuevos desde 1.0.5 que usa la vista previa local: `get.geojs.io`, `cdn.simpleicons.org`, `images.unsplash.com`, `raw.githubusercontent.com`, `api-free.deepl.com` no: el script de DeepL se ejecuta en CI con su secreto, nunca en el contenedor.

4 Parte B · Sitio público

4.1 Cloudflare delante de GitHub Pages

- Añadir `lameyer.net` a Cloudflare (plan gratuito) y cambiar los NS en Namecheap a los que asigne Cloudflare.
- Registros A/AAAA de GitHub Pages y `CNAME www` con **proxy activado** (nube naranja). Ningún registro sin proxy que apunte al origen.
- SSL/TLS en **Full (strict)**; «Always Use HTTPS»; TLS mínimo 1.2.
- DNSSEC** en Cloudflare y el registro DS en Namecheap.
- CAA** solo para las autoridades que use Cloudflare para el certificado del edge (Cloudflare las añade al activar CAA) y la de GitHub Pages (Let's Encrypt).

Verificar en la migración. GitHub Pages emite su certificado por desafío HTTP. Mantener los registros sin proxy hasta que GitHub muestre el certificado como emitido y comprobar después de activar el proxy que «Enforce HTTPS» sigue disponible y que la renovación funciona.

4.2 Cabeceras de seguridad

GitHub Pages no permite cabeceras propias, así que se añaden en Cloudflare con una regla de *Transform Rules* → *Response Header Modification* para todo el host:

```

Strict-Transport-Security: max-age=300 // subir a 31536000 tras una semana sin incidencias;
luego includeSubDomains
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=(), usb=()
X-Frame-Options: DENY // equivalente a frame-ancestors 'none' para
navegadores antiguos
Cross-Origin-Opener-Policy: same-origin

```

`geolocation=()` no afecta a la elección de país: el sitio usa la zona horaria y la IP, nunca la API de geolocalización del navegador.

4.3 Content-Security-Policy

Mientras Babel compile el JSX en el navegador, la CSP necesita `'unsafe-inline'` y `'unsafe-eval'` en `script-src`, lo que le quita la mayor parte de su valor contra XSS. Plan en dos pasos:

Paso	Política
1 · Ahora, <code>Report-Only</code>	Lista de orígenes reales para descubrir dependencias olvidadas sin romper nada (abajo).
2 · Con build	Tras la opción A o B de 1.0.5 (JSX compilado, Tailwind generado): <code>script-src 'self'</code> sin <code>unsafe-*</code> , aplicada (no Report-Only).

Content-Security-Policy-Report-Only (paso 1)

```

default-src 'self';
script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdnjs.cloudflare.com https://cdn.tailwindcss.com;
style-src 'self' 'unsafe-inline' https://fonts.googleapis.com;
font-src https://fonts.gstatic.com;
img-src 'self' data: https://cdn.simpleicons.org https://images.unsplash.com https://placeholder.co
https://raw.githubusercontent.com;
connect-src 'self' https://api.frankfurter.dev https://get.geojs.io https://script.google.com
https://script.googleusercontent.com;
form-action 'self'; base-uri 'self'; object-src 'none'; frame-ancestors 'none';
report-uri https://<endpoint-de-informes>

```

El endpoint de informes puede ser un Worker de Cloudflare que guarde las violaciones en Workers Analytics Engine. CI añade una regla a `checks.sh` (doc. 5 §4.4) que falla si aparece `dangerouslySetInnerHTML`, `innerHTML =`, `eval()` o `new Function` en `js/`, `pages/` o `blog/`.

4.4 Integridad de los scripts (SRI)

Calculado el 2026-10-05 sobre los archivos que sirve cdnjs. Añadir `integrity` y `crossorigin="anonymous"` en todas las páginas (y en la plantilla de `tools/generar-paginas-producto.py`):

```

react/18.2.0/umd/react.production.min.js          sha384-
tMH8h3BGESGckSAVGZ82T9n90ztNXxvdwvdM6UoR56cYcf+0iGXBliJ29D+wZ/x8
react-dom/18.2.0/umd/react-dom.production.min.js  sha384-
bm7MnzvK++ykSwJ2tynSE5TRdN+XL418osEVF2DE/L/gfWHj91J2Sphe582B1Bh
babel-standalone/7.23.5/babel.min.js              sha384-
1q1E7MZPM2pHD/pBZCU/yB8UCP52RYL8bge/qNdfNBCWToySp8/M+JL2waXU4hjJ

```

El Play CDN de Tailwind genera el CSS al vuelo y no admite SRI: desaparece con el paso de build. Hasta entonces es el riesgo residual principal de la cadena de suministro.

4.5 Formularios

- **Contacto:** añadir Cloudflare Turnstile al formulario y enviarlo a un Worker propio que valide el token, aplique un límite por IP (binding de rate limiting, p. ej. 5 envíos / 10 min) y reenvíe a Apps Script con un secreto compartido. La URL de Apps Script deja de estar en el cliente.
- Mantener el campo trampa; el Worker descarta en silencio los envíos que lo rellenen.
- Apps Script: comprobar el secreto compartido y rechazar campos de más de 500 caracteres; anteponer `'` a valores que empiecen por `=`, `+`, `-` o `@` (inyección de fórmulas en Sheets).

4.6 Pedidos por WhatsApp

El navegador no es fuente de verdad. Control documentado: antes de confirmar un pedido, Lameyer comprueba cada SKU, precio y stock contra `public/db/productos.json` (o la base de datos real), nunca contra el texto del mensaje.

Cuando haya pago en línea, el importe se calcula en el servidor.

4.7 Terceros y privacidad

Tercero	Recibe	Medida propuesta
Google Fonts	IP y página, en cada visita	Alojar Plus Jakarta Sans en <code>/fonts/</code> ; quita además dos orígenes de la CSP.
GeoJS	IP, una vez, si no hay bandera	Decisión pendiente: mantenerla como funcional (ya informada en los términos) o pedirla solo tras el consentimiento y usar mientras tanto la zona horaria.
Simple Icons, Unsplash, GitHub (logo)	IP	Copiar los SVG y la imagen al repositorio.
Frankfurter	IP	Cachear el tipo de cambio en un Worker o en build; el cliente lo pide a <code>'self'</code> .
Apps Script, WhatsApp	Datos del formulario / del pedido	Ya informados en «Protección de datos»; tras §4.5, Apps Script solo recibe datos desde el Worker.

4.8 Datos en el navegador

Clave	Contenido	Regla
<code>lm-users</code> , <code>lm-session</code>	Cuentas de staging (hash + sal)	Ocultar «Crear cuenta» en producción hasta Supabase Auth; borrar ambas claves en la primera carga tras el cambio.
<code>lm-cart</code> , <code>lm-locale</code> , <code>lm-geo</code> , <code>lm-cookies</code>	Carrito, bandera, país estimado, consentimiento	Sin datos personales; se mantienen. Nunca guardar tokens de Supabase fuera del almacenamiento que gestione su SDK.

4.9 Después de la puerta: Supabase e IAM

Sin cambios respecto al documento 5 §8: clave publicable en el cliente solo con RLS en todas las tablas; clave secreta solo en secretos de Worker o de entorno de GitHub; contraseña de la base de datos en el gestor de contraseñas; token de la CLI solo en el equipo de la persona; migraciones revisadas y aplicadas por CI con revisor obligatorio; dos miembros con MFA; proyectos de staging y producción separados.

5 Plan de despliegue

Fase	Trabajo	Hecho cuando
0-4 · Desarrollo	Higiene, hooks, servidor, contenedor y puerta del documento 5 §7.	Pruebas 1-13 superadas
5 · DNS	§4.1: Cloudflare, proxy, Full (strict), DNSSEC, CAA. Corregir la línea del readme sobre el proxy.	Pruebas 14-16
6 · Cabeceras	§4.2 aplicadas; §4.3 en Report-Only con endpoint de informes; §4.4 SRI.	Pruebas 17-19; una semana sin violaciones inesperadas
7 · Formularios	§4.5 Turnstile + Worker + endurecer Apps Script.	Pruebas 20-21
8 · Terceros	§4.7 fuentes, iconos e imágenes propias; decisión sobre GeoJS.	Prueba 22
9 · CSP estricta	Tras la opción A o B de 1.0.5: CSP aplicada sin <code>unsafe-*</code> .	Prueba 23

6 Matriz de pruebas

Las pruebas 1-13 son las del documento 5 §6. Se añaden las del sitio público:

#	Intento / comprobación	Resultado esperado
14	<code>curl -sI https://lameyer.net/</code>	Aparece <code>cf-ray</code> ; <code>server: cloudflare</code>
15	Consulta DoH de <code>lameyer.net</code> tipo A	Respuesta con bandera <code>AD</code> (DNSSEC validado)
16	Consulta del registro CAA	Solo las autoridades previstas

17	<code>curl -sI</code> en / , /pages/terminos/ y un artículo del blog	Todas las cabeceras del §4.2 y la CSP Report-Only
18	Recorrido con navegador headless por todas las páginas	Cero violaciones de CSP inesperadas en el endpoint de informes
19	Cambiar un carácter del <code>integrity</code> de React en una copia local	El navegador bloquea el script
20	POST al Worker del formulario sin token de Turnstile	403, nada llega a la hoja
21	6 envíos válidos en 10 minutos desde la misma IP	El sexto recibe 429
22	Cargar el sitio con las peticiones a fonts.googleapis.com y cdn.simpleicons.org bloqueadas	Aspecto idéntico
23	Injectar <code><script>alert(1)</script></code> en una página de prueba	Bloqueado por la CSP aplicada

7 Decisiones abiertas

- GeoJS antes o después del consentimiento (§4.7).
- Endpoint de informes de CSP: Worker propio o servicio externo.
- Dónde vive el Worker del formulario (misma zona, ruta [/api/contacto](#)).
- Si los documentos 5 y 1.0.6 se fusionan en uno solo al cerrar la versión.

8 Notas

- El documento 5 ([_docs/src/v5-dev-security.html](#) y su PDF) no se ha modificado ni añadido al repositorio; sigue sin seguimiento en Git.
- Las comprobaciones del §2 son de una sola consulta desde una red; repetirlas al empezar cada fase.
- Hashes SRI válidos solo para esas versiones exactas; al actualizar una librería hay que recalcularlos.